

Integrity and retention: Object Lock, Vault Lock and surviving ransomware

Making data undeletable – and the failure mode that immutability does not solve.

A backup an attacker can delete is not a backup. Neither is one **you** cannot reach.

Versioning first

- ◆ **Versioning is the prerequisite for everything else.** Without it, an overwrite destroys the previous object.
- ◆ A **simple DELETE** deletes nothing – it inserts a **delete marker** that becomes the current version.
- ◆ So recovery from a naive deletion is removing the marker. Good news, and a trap.
- ◆ **MFA delete** requires a code to delete a version. Configured by the bucket owner's root user only.
- ◆ Versioning alone stops nothing determined. DeleteObjectVersion removes every version.

ON THE EXAM

Versioning protects against mistakes. Object Lock protects against intent.

Object Lock: three protections

PROTECTION	WHO CAN REMOVE IT	USE WHEN
Governance retention	Anyone with <code>s3:BypassGovernanceRetention</code>	Protect from mistakes, keep a break-glass path
Compliance retention	Nobody. Not even the account root user	A regulator requires provable immutability
Legal hold	Anyone with <code>s3:PutObjectLegalHold</code>	Indefinite hold with no end date, e.g. litigation

ON THE EXAM

Legal hold has no retention period and no expiry. It sits alongside a retention period rather than replacing it.

Object Lock mechanics

- ◆ **Object Lock must be enabled when the bucket is created, and versioning must be on.**
- ◆ Protection applies to **object versions**, not object names. A new version can still be written; the old one stays protected.
- ◆ A **simple DELETE still returns 200 OK** and inserts a delete marker. The protected version survives underneath it.
- ◆ That is why 'we deleted it and S3 said OK' is not evidence the object is gone.
- ◆ Condition keys let you constrain it: **s3:object-lock-mode**, **s3:object-lock-retain-until-date**, **s3:object-lock-remaining-retention-days**.

ON THE EXAM

You can set a default retention on the bucket so every new object inherits it. Otherwise it is per-object and easy to miss.

Vault Lock, twice over

- ◆ **S3 Glacier Vault Lock** – a WORM policy on a vault. In progress while you test, then **complete and immutable**.
- ◆ **AWS Backup Vault Lock** – the same idea for backups, and what ransomware scenarios want.
- ◆ **Governance mode** is removable with `backup:DeleteBackupVaultLockConfiguration`.
- ◆ **Compliance mode becomes permanent once the grace period expires**. No AWS process reverses it.
- ◆ Assessed by Cohasset Associates against **SEC 17a-4, CFTC and FINRA**.

ON THE EXAM

The grace period is for testing. Once it lapses, a wrong retention is wrong for its whole duration.

Logically air-gapped vaults

- ◆ A secondary vault type holding **copies** of backups, designed for ransomware resilience.
- ◆ **Every logically air-gapped vault is automatically Vault Locked in compliance mode.** You do not opt in.
- ◆ Encrypted with an AWS owned key by default, or optionally a customer managed key. The key type is visible through the API for compliance reporting.
- ◆ **Shareable through AWS RAM** with other accounts, **including accounts in other organizations**, so backups can be restored from elsewhere.
- ◆ Since **November 2025** it can be the **primary backup target**, not only a copy destination.

ON THE EXAM

Sharing across organisations is the unusual part. It exists so recovery does not depend on your own organisation surviving.

The failure immutability does not solve

- ◆ **The hardest ransomware case is not deletion. It is lockout.** An attacker takes root in the backup account.
- ◆ Backups perfectly preserved, and perfectly unreachable. Vault Lock made that worse.
- ◆ **Multi-party approval, GA since June 2025, enables recovery even if the vault-owning account is inaccessible.**
- ◆ A quorum of approvers outside the compromised account authorises the recovery.
- ◆ With RAM sharing, recovery no longer depends on your organisation surviving.

ON THE EXAM

Vault Lock answers 'can they delete it'. MPA answers 'can we still get it back'.

What a ransomware-resistant design actually looks like

- ◆ **Versioning and Object Lock** on the data; **Vault Lock** on the backups.
- ◆ **Copies in a separate account** with no trust path back, ideally a separate Region.
- ◆ **GuardDuty Malware Protection for AWS Backup**, so you do not restore the malware too.
- ◆ **Backup policies in AWS Organizations**, so a member account cannot stop backing up.
- ◆ **Test restores**. An untested backup is the module 9 lesson: a hypothesis, not a control.

ON THE EXAM

Backups that preserve the malware are a real failure mode. Scanning is what stops it recurring.

A broker-dealer must retain trade records for seven years in a form that cannot be altered or deleted by anyone, including its own administrators and the account root user. The regulator will audit the technical control, not just the policy document.

The security team proposes S3 versioning with MFA delete, plus a bucket policy denying s3:DeleteObjectVersion to everyone except a break-glass role.

What should the team implement instead?

- ☐ A Their proposal, with the break-glass role's use alarmed in CloudWatch
- ☐ B S3 Object Lock in governance mode with a seven-year retention period
- ☐ C Glacier Deep Archive with a lifecycle rule preventing early deletion
- ☐ D S3 Object Lock in compliance mode with a seven-year retention period

◆ PAUSE AND DECIDE

What should the team implement instead?

A Versioning, MFA delete and a bucket policy
A policy control, and a policy can be edited by whoever administers it. The requirement explicitly includes the root user, who can change any bucket policy.

C Glacier Deep Archive with lifecycle
A storage class and a cost control. Early-deletion charges discourage deletion; they do not prevent it.

B Object Lock, governance mode
The near miss. Governance mode is deliberately bypassable by anyone holding `s3:BypassGovernanceRetention`, which is exactly the exception the regulator excludes.

D Object Lock, compliance mode
Correct. In compliance mode no user can delete or shorten the retention, including the account root user – which is the requirement stated almost word for word.

THE SIGNAL

'Including the account root user' is the phrase. Only compliance mode makes that claim, and AWS states it in those words.

An attacker obtains root credentials for a company's dedicated backup account, changes the root email address and MFA device, and locks the security team out. The backups are held in a logically air-gapped vault and cannot be deleted.

The production estate has been encrypted by ransomware. The backups exist, are provably intact, and nobody at the company can reach the account holding them.

What capability would have allowed recovery?

- ☐ A AWS Backup Vault Lock in compliance mode on the vault
- ☐ B Multi-party approval on the logically air-gapped vault, with approvers outside that account
- ☐ C Cross-Region copies of the vault into a second Region
- ☐ D GuardDuty Malware Protection for AWS Backup on the vault

◆ PAUSE AND DECIDE

What capability would have allowed recovery?

A Vault Lock in compliance mode

Already present - every logically air-gapped vault has it automatically. It is why the backups survived, and it does nothing about reaching them.

C Cross-Region copies

Protects against a Regional failure. Both Regions sit inside the same locked-out account, so the second copy is equally unreachable.

B Multi-party approval with approvers outside the account

Correct. MPA exists for exactly this: recovery from a logically air-gapped vault when the vault-owning account is inaccessible, authorised by a quorum elsewhere.

D Malware Protection for AWS Backup

Stops you restoring the malware with the data - valuable, and only once you can reach the backups at all.

THE SIGNAL

Immutability solved deletion and created the lockout problem. Option A is not wrong so much as already true.

A compliance officer reports that Object Lock is not working. She issued a DELETE request against an object in a bucket with Object Lock in compliance mode and a two-year retention period. S3 returned 200 OK, and the object no longer appears in the console listing. The retention period has eighteen months left to run.

What has actually happened?

- ☐ A Nothing was deleted; a delete marker was inserted, and the protected version remains
- ☐ B Compliance mode permits deletion by the object owner, which is what occurred
- ☐ C The object had a legal hold that expired, releasing the retention early
- ☐ D Object Lock only applies to objects uploaded after it is enabled; this one predates it

◆ PAUSE AND DECIDE

What has actually happened?

- A

 A delete marker was inserted; the version remains
Correct. A DELETE without a version ID on a versioned bucket returns 200 OK and inserts a delete marker. The protected version is untouched underneath it.
- B

 Compliance mode permits owner deletion
The opposite of what compliance mode means. AWS is explicit: no user, including the account root user, can delete during the retention period.
- C

 An expired legal hold released the retention
Legal holds have no expiry, and they sit alongside a retention period rather than controlling it. Removing one would not shorten retention.
- D

 Object Lock only covers objects uploaded afterwards
Object Lock is enabled at bucket creation, so there are no pre-existing objects. Protection is applied per version regardless.

THE SIGNAL

'S3 said OK' and 'it is gone from the listing' are the same event, and neither means deletion. Check for the version, not the name.

A healthcare provider applies AWS Backup Vault Lock in compliance mode to its production vault, setting a minimum retention of ten years. Two days later, a review finds the correct regulatory requirement is six years, and that ten years will cost roughly three times as much in storage.

The lock was created with a grace period that has not yet expired.

What should the provider do?

- ☐ A Nothing can be changed; compliance mode is immutable from the moment it is applied
- ☐ B Delete the vault and recreate it with the correct retention
- ☐ C Change the lock configuration now, while the grace period is still running
- ☐ D Switch the lock to governance mode, adjust the retention, then switch back

◆ PAUSE AND DECIDE

What should the provider do?

A Nothing can be changed

True after the grace period, not during it. The grace period exists precisely so a configuration can be tested and corrected before it becomes permanent.

C Change it now, during the grace period

Correct. The grace period is a deliberate cooling-off window. Once it expires, the compliance lock is permanent and irreversible.

B Delete and recreate the vault

A vault holding compliance-locked recovery points cannot simply be deleted – which is the whole point of the lock.

D Switch to governance, adjust, switch back

You cannot downgrade a compliance lock to governance. If you could, compliance mode would guarantee nothing.

THE SIGNAL

The scenario tells you the grace period has not expired. That clause is the entire question.

Six things to carry forward

- ◆ **Versioning protects against mistakes. Object Lock protects against intent.**
- ◆ **Compliance mode: nobody, including the account root user.** Governance mode has a documented bypass permission.
- ◆ **A DELETE without a version ID returns 200 OK and inserts a delete marker.** Nothing was destroyed.
- ◆ **Object Lock is enabled at bucket creation,** and versioning must be on.
- ◆ **Every logically air-gapped vault is compliance-locked automatically,** and can be shared across organisations via RAM.
- ◆ **Immutability solves deletion, not lockout.** Multi-party approval is the answer to lockout.

ON THE EXAM

Next: data in transit – ACM, Private CA, TLS enforcement, PrivateLink and Nitro.